

CHALLENGE #4: Hashgate Write-up.

Hashgate

Medium

Web Exploitation

picoCTF 2026

AUTHOR: YAHAYA MEDDY

Description

You have gotten access to an organisation's portal. Submit your email and password, and it redirects you to your profile. But be careful: just because access to the admin isn't **directly** exposed doesn't mean it's secure. Maybe someone forgot that obscurity isn't security... Can you find your way into the admin's profile for this organisation and capture the flag? Additional details will be available after launching your challenge instance.

This challenge launches an instance on demand.

Its current status is:

NOT_RUNNING

Launch Instance

Hints ?

1

2

Notice anything about how the ID is being checked? It's not plain text... maybe a one-way function is involved.

1,832 users solved

🚩 picoCTF{FLAG}

Hints ?

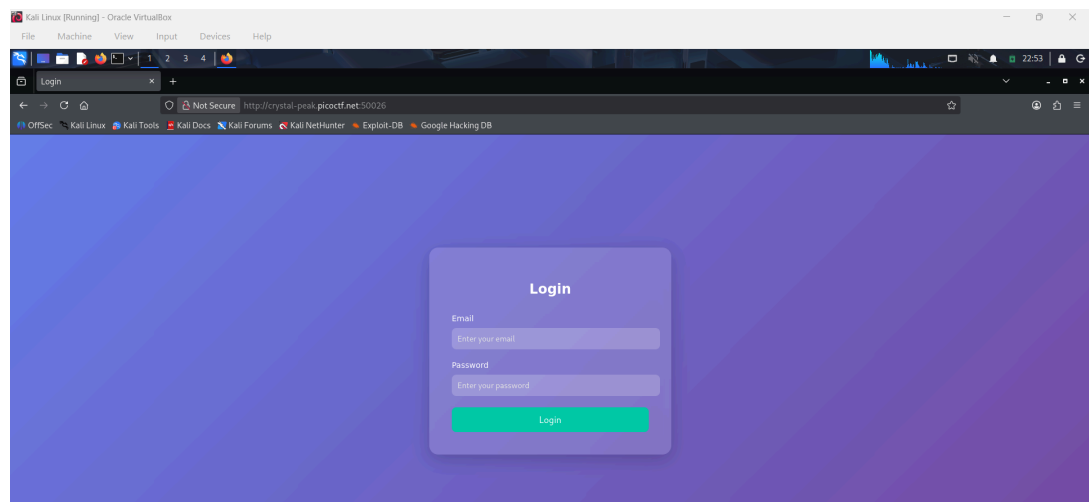
1

2

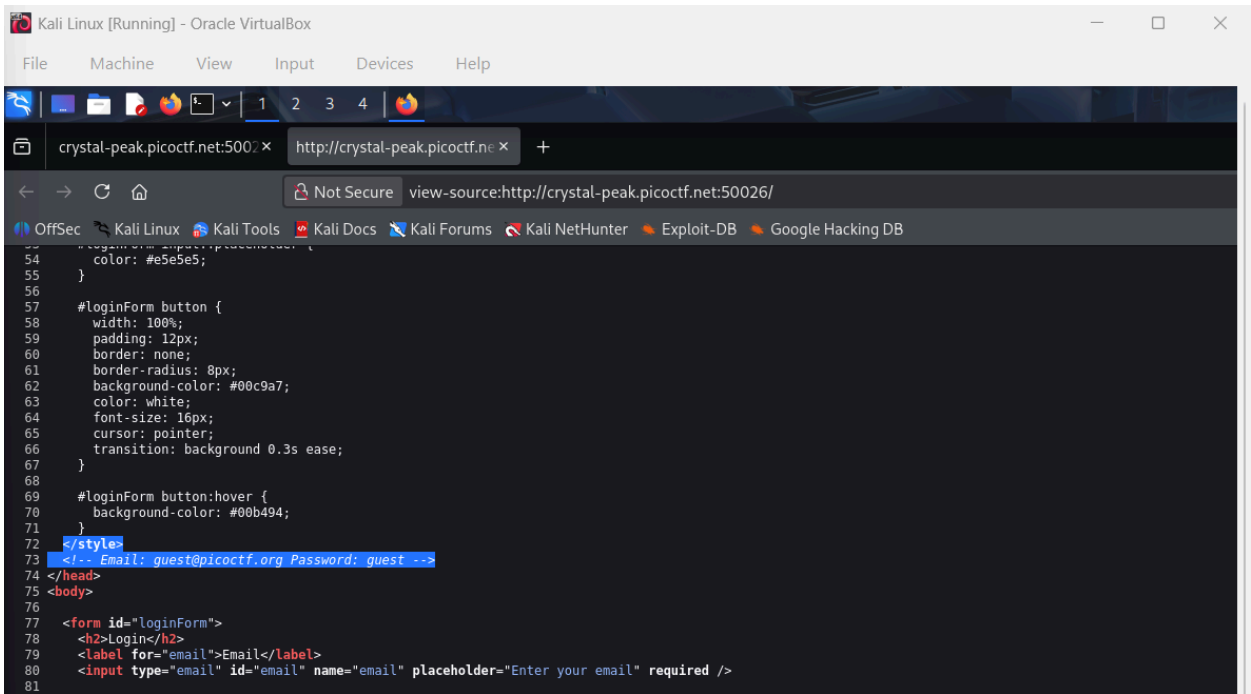
There are about 20 employees in this organisation.

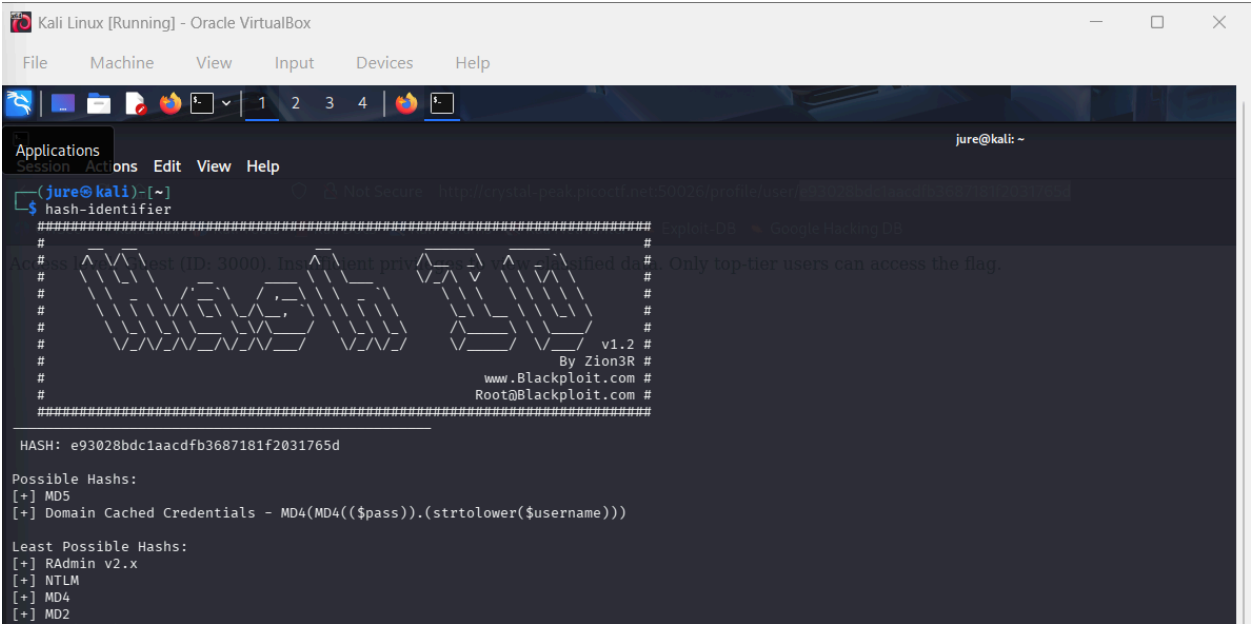
Solving Process:

The challenge began by opening the provided link, which led to an organization's login portal. The description explained that submitting an email and password would redirect the user to their profile page. However, it also hinted that although access to the admin account was not directly visible, this did not necessarily mean it was secure. The hints provided suggested paying attention to how the ID was checked and noted that the organization had around 20 employees, implying that these details would be important in solving the challenge.

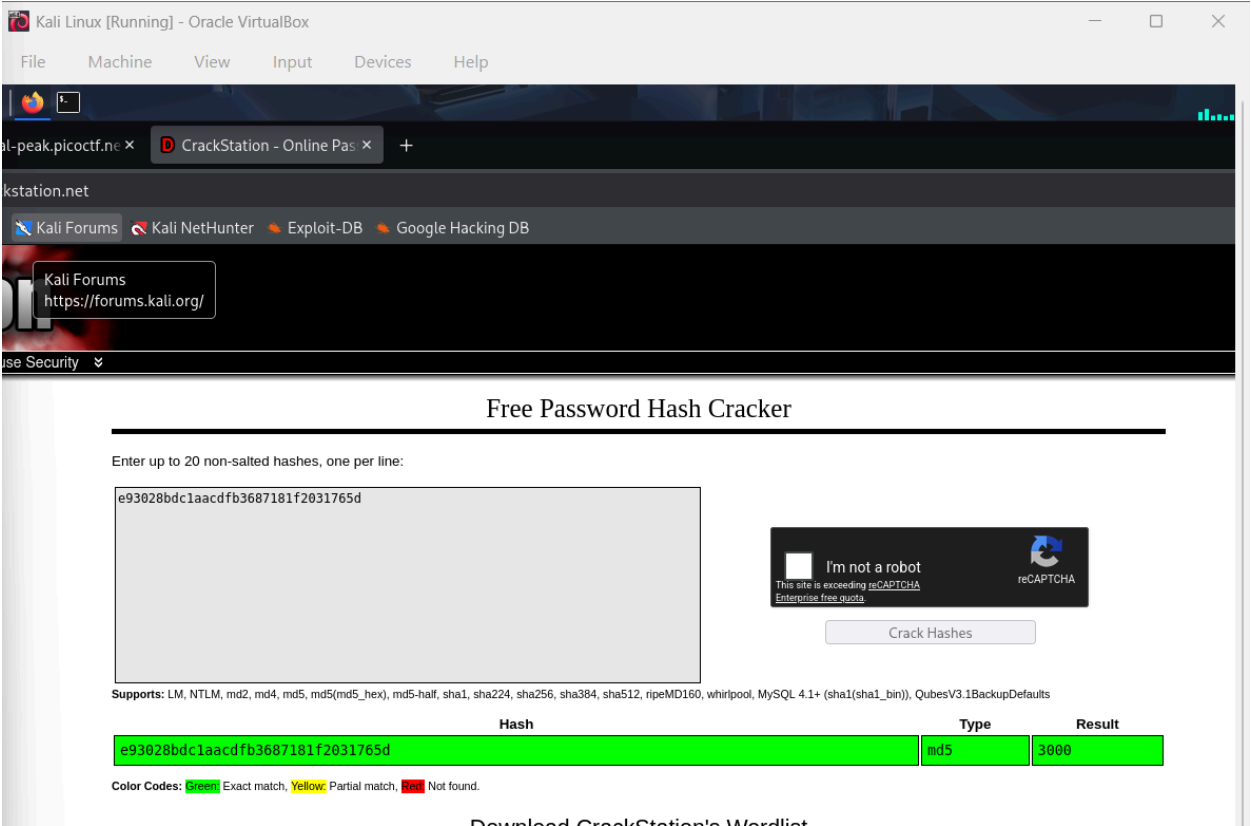


Upon accessing the login page, it was immediately noticeable that there was no sign-up option, meaning new accounts could not be created. Because of this limitation, the next logical step was to inspect the page source to check whether any credentials or hidden information were embedded within the HTML. After viewing the page source, a commented section containing an email and password was discovered. These appeared to be credentials that could be used to access the system.



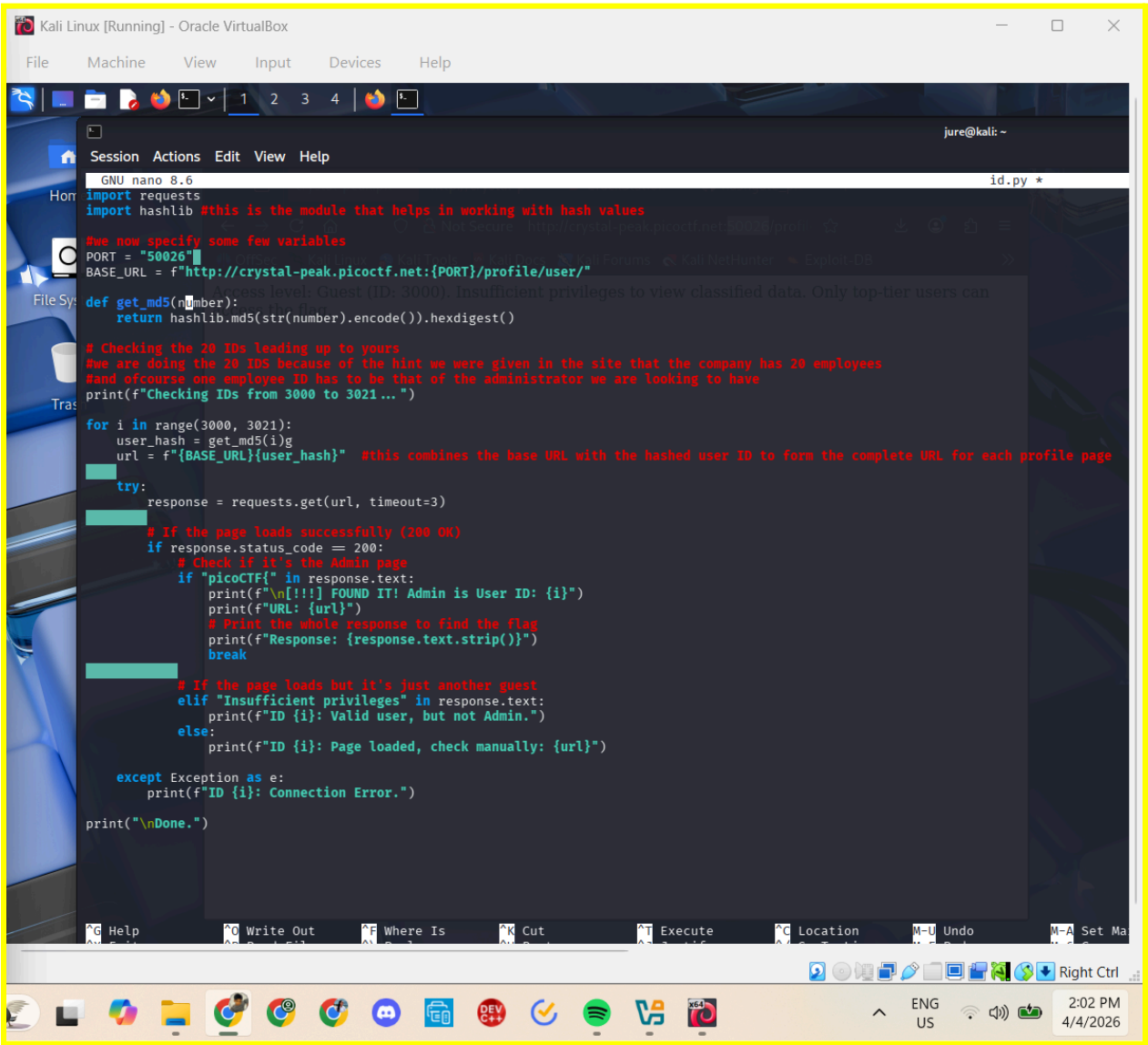
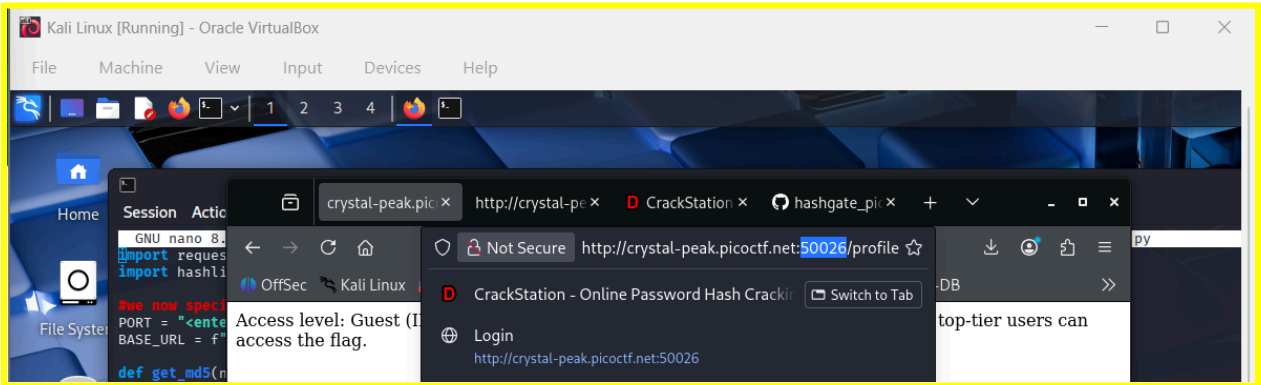


To confirm this, the hash was tested using the online hash-cracking tool **CrackStation**. The tool successfully decoded the hash and revealed that the original value corresponded to the user ID 3000. This meant that the system was likely using the MD5 hash of the user ID as part of its verification process.



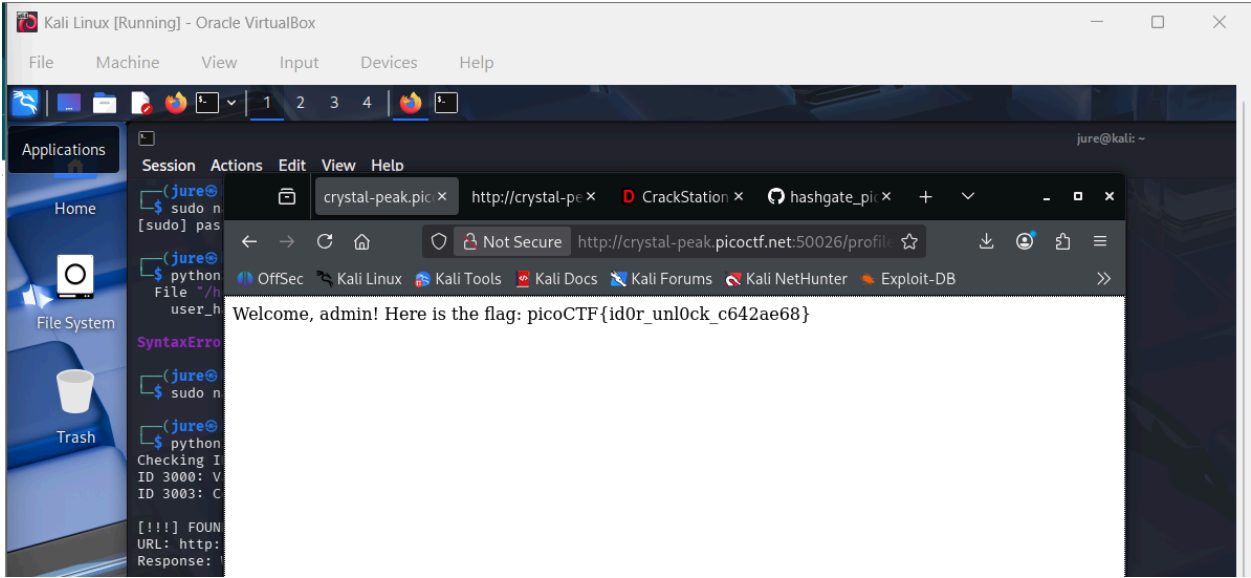
At this point, the next objective was to determine the **administrator's user ID**. The hint mentioning that the organization had about 20 employees suggested that the administrator's ID was probably close to the current user ID. Rather than performing manual tests for each potential ID, I utilized an automated Python script sourced from a previous write-up to streamline the identification process. The script generated possible user IDs within a reasonable

range (for example, values slightly higher than 3000), calculated their MD5 hashes, and tested them against the system to see if any would grant administrator access.



After running the script, a matching hash corresponding to the administrator's user ID was found. This hash was then inserted into the URL parameter that controlled the profile ID. Once the page was refreshed with the new hash value, the application loaded the administrator profile page, which finally displayed the flag for the challenge.





Hashgate

Medium

Web Exploitation

picoCTF 2026

AUTHOR: YAHAYA MEDDY

Description

You have gotten access to an organisation's portal. Submit your email and password, and it redirects you to your profile. But be careful: just because access to the admin isn't **directly** exposed doesn't mean it's secure. Maybe someone forgot that obscurity isn't security... Can you find your way into the admin's profile for this organisation and capture the flag? The website is running [here](#).

This challenge launches an instance on demand.

Its current status is: **RUNNING**

Instance Time Remaining: **14:46**

Restart Instance

Hints ?

1

2

Notice anything about how the ID is being checked? It's not plain text... maybe a one-way function is involved.

1,832 users solved

38%

Liked

picoCTF{id0r_unl0ck_c642ae68}

Submit Flag

Hurray! You solved this challenge.

X

Basically, the solution involved discovering hidden credentials in the page source, understanding that the system relied on hashed user IDs, identifying the hashing method, and then automating the search for the administrator's ID using a script. By replacing the hash in the request with the correct administrator hash, it was possible to access the admin profile and retrieve the flag.

Reflection:

This challenge helped me understand how security through obscurity is not a reliable protection method. Even though the admin access was not directly visible, analyzing the page source, identifying the hashing mechanism, and testing possible user IDs showed how attackers can still bypass such restrictions. The activity highlighted the importance of proper authentication controls and avoiding predictable identifiers in web applications.